SPOTIFY'S DATA & AI GOVERNANCE PROJECT

2.1. *Data & AI Governance Policy* Document

Annexes

> *Nicolas Pichon ~ AIA RNCP 38777 / BC01 / Step 2-1 / Annexes / v15 ~ 2026/10/15.*

2.1.A. Détails de la classification des modèles par niveau d'impact

2.1.A.1. Définition des niveaux d'impact des modèles

Le *niveau d'impact* d'un modèle est évalué en fonction des critères suivants :

- Sa *portée* : la proportion des utilisateurs actifs exposés à la décision du modèle ;
- Sa *réversibilité* : la possibilité de corriger une décision erronée dans un délai court ;
- Son *exposition réglementaire* : le modèle relève-t-il d'un traitement de données personnelles sensibles ou d'une décision individuelle automatisée au sens de l'article 22 du RGPD ?
- Sa *priorité fonctionnelle* : le modèle implémente-t-il une fonctionnalité principale du produit (recommandation, personnalisation) ou une fonction auxiliaire?

Trois niveaux d'impact sont définis en fonction de ces critères :

Niveau	Critères
fort	Au moins l'un des critères suivants est satisfait :
	--- La majorité des utilisateurs actifs sont concernés
	--- La décision de déploiement est difficilement réversible
	--- La fonction est exposée réglementairement (données sensibles, automatisation)
	--- La fonctionnalité est principale (ex.: le système de recommandation)
modéré	Les critères forts ne sont pas satisfait mais au moins l'un des critères suivants l'est :
	--- Seuls des utilisateurs ciblés (cohorte, marché, A/B test) sont concernés
	--- La décision de déploiement est réversible sous un délai court
faible	Niveau d'impact part défaut (aucun des critères fort/modéré n'est satisfait) :
	--- Fonction auxiliaire sans exposition directe à l'utilisateur final

2.1.A.3. Circuits d'approbation des modèles en fonction des niveaux d'impact

Niveau	Circuit d'approbation de déploiement d'un version
fort	*MO* (C) → *MRM* (R) → *DGC* (A)
modéré	*MO* (R) → *MRM* (A)
faible	*MO* (RA) = auto-certification sur la base d'une checklist + *MRM* = contrôle a posteriori / échantillonnage

> *Légende :*
>
> - *Rôles MO, MRM, DGC : cf. rôles dans [D22],*
> - *Responsabilités : R = Responsible, A = Accountable, C = Consulted (cf. matrices RACI dans [D22-Annexes, §2.2.C]).*

2.1.A.4. Classification, approbation et reclassification des modèles

- La *classification* d'un modèle en fonction de son niveau d'impact porte sur le modèle en tant qu'entité conceptuelle et n'a lieu qu'une seule fois, lors de son enregistrement dans le registre des modèles.
- L'*approbation de déploiement* porte sur une version particulière du modèle ; elle se répète à chaque mise en production et hérite du niveau d'impact du modèle, fixé lors de la classification. La question de la classification n'est jamais réouverte à ce niveau.

- La *reclassification* d'un modèle est un événement rare, déclenché soit par une modification substantielle du modèle (changement de finalité, extension de la portée d'usage), soit par une détection lors de l'audit par échantillonnage.

Les responsabilités associées (*RACI*) figurent dans [D22-Annexes, §2.2.C].

2.1.B. Couverture des enjeux identifiés en évaluation

Le tableau ci-dessous relie les enjeux majeurs identifiés dans [D1] aux dispositions de la politique [D21] .

#	Enjeu	Dispositions de la politique qui y répondent
E1	Décompartimenter les données	Responsabilité par actif (P1) ; Rôles *DO*/*DS* à double rattachement (§2.1.6 & [D22]) ; Standardisation de la qualité (P4)
E2	Maîtriser la qualité des données	Règles de qualité mesurables et audits (P4) ; Traitement spécifique des données d'apprentissage (§2.1.5)
E3	Maîtriser la mise en conformité réglementaire dans un contexte multi-juridictionnel	P5 ; Socle *RGPD*/*CCPA*/*PCI-DSS* (§2.1.4) ; Processus de cartographie réglementaire par marché piloté par *DPO*/*Legal Team* (§2.1.4)
E4	Garantir la vie privée et l'usage éthique des données	Transparence (P2) ; Minimisation (P6) ; Droits et anonymisation (P7) ; Ethique (P8) ; biais, explicabilité (§2.1.5)
E5	Gouverner spécifiquement les données IA	P8 ; Traçabilité, biais, approbation des modèles, explicabilité (§2.1.5) ; Rôles *MO* & *MRM* (§2.1.6).
E6	Accompagner la montée en compétences data	Responsabilité partagée (P1) ; Intégration des rôles de métier comme parties prenantes de la gouvernance (§2.1.6) ; Amélioration continue (P9).

> *Légende : DO, DS, DPO, Legal Team, MO, MRM : cf. rôles dans [D22].*

2.1.C. Couverture des actions attendues en gouvernance

Le tableau ci-dessous relie les actions de principe attendues dans le guide des principes de gouvernance [R4] aux dispositions de la présente politique [D21].

#	Principe [R4]	Action attendue	Enjeux	Réponse de la politique	
P1	Responsabilité	Définir les rôles et responsabilités de propriété et de responsabilité des données	E1, E6	Rôles *DO*/*DS*/*MO* définis et opérationnalisés dans l'organigramme [D22] ; la chaîne *CDO*/*DO*/*DS* évite le silotage (E1), le partage de rôles entre métiers diffuse la responsabilité (E6).	
P2	Transparence	Mettre en place des mentions d'information et une gestion du consentement conformes	E4 (E3)	§2.1.4 (consentement explicite *RGPD*, opt-out *CCPA*) ; étendue à la transparence sur la collecte, l'usage et le partage (E4).	
P3	Sécurité	Garantir contrôle d'accès approprié, chiffrement, protocoles de réponse aux violations	(transv. E3, E4)	P3 (chiffrement, accès par rôle, *PCI-DSS*) ; réponse aux violations au §2.1.4. Principe transversal, sans enjeu majeur dédié dans [D1].	
P4	Qualité	Établir des indicateurs de qualité et mettre en œuvre des audits réguliers	E2, E1	P4 (règles mesurables auditées) ; Responsabilités définies dans [D22].	
P5	Conformité	Réaliser des revues régulières pour suivre l'évolution des lois de protection des données	E3	P5 (veille légale) ; enjeu multi-juridictionnel pris en compte par la cartographie réglementaire (§2.1.4).	
P6	Minimisation	Mettre en oeuvre des politiques de collecte strictes et minimisées	E4	P6 (collecte limitée au nécessaire) + anonymisation ; réduit l'exposition au risque et la matière première des inférences intrusives.	
P7	Droits des utilisateurs	Mettre en place des systèmes permettant l'exercice de ces droits	E4	P7 + §2.1.4 (accès, modification, suppression, opposition) ; Responsabilités définies dans [D22] (*DPO* "*Accountable*" sur les demandes)	
P8	Usage éthique	Garantir l'intégration de lignes directrices éthiques dans les projets data & IA	E5, E4	Transformé en quatre exigences concrètes au §2.1.5 (lineage, biais, approbation, explicabilité), opérationnalisées par les rôles *MO*/*MRM* de [D22]	
P9	Amélioration continue	Revoir et actualiser régulièrement le cadre de gouvernance, en intégrant les retours et bonnes pratiques	E6 (transv.)	Revues périodiques au §2.1.7, rendues mesurables par la méthodologie *DMAT* [R1] et par un objectif chiffré (niveau 1 > niveau 3)	

> *Légende : CDO, DO, DS, MO, MRM : cf. rôles dans [D22].*

Références

Livrables

- [D1] *Data Maturity Assessment Report*
- [D21] *Data Governance Policy Document*
- [D22] *Organizational Chart*

Annexes

- [D22-Annexes] *Organizational Chart's Annexes*

Ressources

- [R1] Australian Government Data Maturity Assessment Tool (2026)
- [R4] Governance Principles Guide